CAS PRATIQUE — DIRECTIVE (UE) 2022/2555

Mise en conformité NIS2

HydroRégie — régie des eaux, 450 000 habitants desservis

Bloc 1 Qualification · Bloc 2 Analyse d'écart · Bloc 3 Architecture IT/OT · Bloc 4 Gestion de crise

Projet B3 — Administration systèmes et réseaux

LE POINT DE DÉPART

Une régie vitale sur un réseau sans cloisonnement

450 000
habitants desservis
62 communes

240 000
abonnés facturés
1 200 km de réseau

~350
automates et RTU
pilotant le procédé

380
salariés
72 M€ de CA

- Un **seul réseau à plat** : la bureautique et les automates partagent le même plan d'adressage
- Six étapes suffisent : courriel piégé → exécution → scan → découverte du SCADA → session Modbus → **écriture d'un registre**
- **Aucune de ces six étapes n'est bloquée aujourd'hui**

L'enjeu n'est pas la fuite de données. C'est **la continuité et la qualité de l'eau potable** — donc la santé publique.

MÉTHODE

Qualifier une entité en quatre questions

Une méthode réutilisable pour n'importe quelle organisation, pas seulement pour ce cas.

- **Q1 — Le secteur.** Figure-t-il aux annexes I ou II ? art. 2(1)
- **Q2 — La taille.** Au sens de la recommandation 2003/361/CE
- **Q3 — Le croisement.** Secteur × taille → statut art. 3
- **Q4 — Les cas particuliers.** art. 2(2) ignore la taille

SEUIL DE LA GRANDE ENTREPRISE

250 salariés ou plus

— ou —

CA > 50 M€ **ET** bilan > 43 M€

Le piège : l'effectif est un critère **autonome**. Mais en dessous de 250, il faut dépasser les **deux** critères financiers.

> Ce raisonnement est la trame de toute la présentation : à chaque fois **un tableau de règles**, **la situation d'HydroRégie**, **la conclusion qui s'impose**.

Q3 — LE CROISEMENT

La grille de qualification, appliquée

SITUATION	STATUT NIS2	FONDEMENT · CONSÉQUENCE
▸ Annexe I + grande entreprise **MON CAS**	ENTITÉ ESSENTIELLE	art. 3(1)(a) — supervision **ex ante**
Annexe I + moyenne entreprise	Entité importante	art. 3(2) — supervision ex post
Annexe II + grande entreprise	Entité importante	art. 3(2)
Annexe II + moyenne entreprise	Entité importante	art. 3(2)
Petite ou micro entreprise	Hors champ	sauf art. 2(2)

TROIS VOIES INDÉPENDANTES MÈNENT À LA MÊME CASE

VOIE 1 — SECTEUR + EFFECTIF

Eau potable (annexe I, pt 6) et **380 salariés** ≥ 250.
L'effectif est un critère **autonome** : il suffit.

VOIE 2 — SECTEUR + FINANCES

72 M€ de CA > 50 M€ *et* **95 M€** de bilan > 43 M€.
Même résultat sans regarder l'effectif.

VOIE 3 — IMPACT SOCIÉTAL

Seul distributeur du territoire, enjeu de santé publique.
Art. 2(2)(e) et (g) — la taille devient **indifférente**.

CE QUE DIT LE TABLEAU

Le statut se déduit du **croisement** secteur × taille.
Rien d'autre n'entre en compte.

→

OÙ SE SITUE HYDRORÉGIE

Eau potable = **annexe I, point 6**.
380 salariés ≥ 250 = **grande entreprise**.

→

DONC JE CONCLUS

Entité essentielle. Audits sans incident préalable, amende jusqu'à **10 M€ ou 2 %** du CA, responsabilité personnelle des dirigeants.

CE QUE LE STATUT DÉCLENCHE

Obligations, autorité compétente et enregistrement

OBLIGATION	ARTICLE	ÉCHÉANCE
Enregistrement auprès de l'autorité	3(4)	Pré-enregistrement possible **dès maintenant**
Mise à jour des informations	3(4)	Sous **2 semaines**
Gouvernance : approbation et formation des dirigeants	**20**	Immédiat
Mesures couvrant les 10 domaines	**21(2)**	Immédiat, avec plan
Prise en compte des fournisseurs directs	21(3)	Immédiat
Correction sans délai des non-conformités	21(4)	Permanent
Notification 24 h / 72 h / 1 mois	**23(4)**	Procédure **à écrire en priorité**
Information des destinataires du service	23(1)	Permanent

AUTORITÉ COMPÉTENTE

ANSSI

France — art. 26(1)
Enregistrement via **MonEspaceNIS2**
CSIRT national : **CERT-FR**

SUPERVISION	ESSENTIELLE	IMPORTANTE
▸ Régime	**Ex ante** + ex post	Ex post
Audits sans incident	**Oui**	**Non**
Amende max.	10 M€ / 2 %	7 M€ / 1,4 %
Interdiction d'exercer	**Possible**	**Non**

Message à la direction : les mesures sont les mêmes qu'une entité importante. Ce qui change, c'est que **le contrôle peut arriver sans prévenir et sans incident** (art. 32(2)), et que la responsabilité personnelle du directeur général est engagée (art. 20(1), 32(5)(b)).

État du droit vérifié au 10 septembre 2026 : la loi française de transposition **n'est pas promulguée** — adoptée au Sénat les 11-12 mars 2025, examinée en commission spéciale à l'Assemblée le 10 septembre 2025. Ce dossier s'appuie donc directement sur **le texte de la directive** — l'obligation naît du texte européen, pas de la loi nationale.

LES 10 FAMILLES DE L'ARTICLE 21

La cotation, famille par famille

ARTICLE	FAMILLE DE MESURES	ÉCART	ACTUEL	CIBLE
21(2)(a)	Analyse de risques et politique SSI	ABSENT	0	3
21(2)(b)	Gestion des incidents	PARTIEL	1	4
21(2)(c)	Continuité d'activité et gestion de crise	PARTIEL	1	4
21(2)(d)	Sécurité de la chaîne d'approvisionnement	ABSENT	0	3
21(2)(e)	Acquisition, développement, maintenance	PARTIEL	1	3
21(2)(f)	Évaluation de l'efficacité des mesures	ABSENT	0	3
21(2)(g)	Hygiène informatique et formation	PARTIEL	1	3
21(2)(h)	Cryptographie et chiffrement	PARTIEL	1	3
21(2)(i)	RH, contrôle d'accès, gestion des actifs	PARTIEL	1	4
21(2)(j)	Authentification forte et communications	ABSENT	0	4
▸ Moyenne	**4 absentes · 6 partielles · aucune conforme** MON CAS	—	0,6	3,3

CE QUE DIT LE TABLEAU

L'article 21 impose les **10 familles**. Chacune se cote de 0 à 4 et se qualifie *absent*, *partiel* ou *conforme*.

→

OÙ SE SITUE HYDRORÉGIE

0,6 / 4 de moyenne. **18 écarts** dont **6 critiques**. Aucune famille n'atteint la conformité.

→

DONC JE CONCLUS

Tout ne peut pas être traité de front : il faut **prioriser**. Et l'art. 21(4) interdit de constater un écart sans agir — **l'inaction est elle-même un manquement**.

L'OUTIL D'ARBITRAGE

Matrice impact / effort

IMPACT	EFFORT FAIBLE	EFFORT ÉLEVÉ
IMPACT ÉLEVÉ	**Prioritaire — phase 0** GAIN RAPIDE · 95 K€ · 3 MOIS • **Procédure de notification** — quelques jours, un risque de sanction supprimé • **MFA** sur admin, accès distants, messagerie • **Gouvernance** : COSSI, RSSI, PSSI art. 20 • Sauvegarde hors ligne (effort moyen) • Suppression des accès permanents (effort moyen)	**Programme — phase 2** À PLANIFIER · 485 K€ · 9 MOIS • **Segmentation IT/OT complète** — le projet structurant, 18 mois avec jalons • Détection et journalisation centralisée • Refonte des accès distants par bastion
IMPACT FAIBLE	**Rapide** SI RESSOURCE DISPONIBLE • Sensibilisation des agents • Inventaire passif des actifs • Politique de mots de passe	**À surveiller** DÉCISION TRACÉE, PAS D'ABANDON • Diode de données — 30 à 80 k€ pour un gain marginal une fois la DMZ en place • Certification art. 24

CE QUE DIT LA MATRICE

Quatre quadrants. L'ordre des travaux suit le **risque évité par euro dépensé**, pas l'ordre des articles.

→

OÙ SE SITUENT MES ÉCARTS

Notification, MFA et gouvernance : **impact élevé, effort faible**. La segmentation : impact élevé, **effort élevé**.

→

DONC JE CHOISIS

De commencer par la **phase 0 à 95 k€**, pas par la segmentation à 485 k€. Le gros projet démarre en parallèle, mais il ne bloque rien.

LE PLAN

24 mois, 956 k€, quatre phases finançables séparément

3 MOIS · 95 k€
Phase 0 — Urgences
Notification · MFA · sauvegardes hors ligne · bastion · gouvernance

6 MOIS · 143 k€
Phase 1 — Socle
Analyse de risques · PSSI · inventaire · matrice de flux

9 MOIS · 485 k€
Phase 2 — Segmentation
Le projet structurant : zones, pare-feu, DMZ, détection

6 MOIS · 103 k€
Phase 3 — Maîtrise
Tests · exercices de crise · audits · indicateurs

- Maturité portée de **0,6 à 3,3 sur 4** — **39 actions** datées, chacune avec un propriétaire nommé
- Soit **1,3 % du chiffre d'affaires** sur deux ans

L'argument budgétaire : 956 k€ de mise en conformité, contre **10 M€** d'amende encourue et **1,18 M€** pour un seul incident. La conformité coûte moins d'un dixième de la sanction, et moins qu'une seule crise.

PHASE 0 — LE DÉTAIL

Le plan d'actions daté et responsabilisé

ID	ACTION	RESPONSABLE	ÉCHÉANCE
A-01	Créer le comité de sécurité (COSSI) par délibération	Direction générale	31/10/2026
A-02	Désigner le RSSI (lettre de mission signée)	Direction générale	31/10/2026
A-03	Créer le compte MonEspaceNIS2, pré-enregistrer	DSI	31/10/2026
▸ **A-04**	**Procédure de notification + 3 modèles + grille** LE PLUS RENTABLE	**RSSI**	**30/11/2026**
A-05	MFA sur l'administration et les accès distants	DSI	30/11/2026
▸ **A-06**	**Sauvegarde hors ligne hebdomadaire** A SAUVÉ LA CRISE	**DSI**	**15/12/2026**
A-07	Versionner tous les programmes automates	Resp. exploitation	15/12/2026
A-08	Supprimer TeamViewer → VPN + MFA + bastion	DSI	31/12/2026
A-09	Annuaire de crise papier + messagerie hors domaine	RSSI	31/12/2026

CE QUE DIT LE TABLEAU

Chaque action porte un **propriétaire nommé** et une **date**. Sans les deux, ce n'est pas un plan.

→

CE QUE ÇA DONNE ICI

9 actions en phase 0, dont 3 sous un mois. **39 au total** sur les quatre phases.

→

DONC JE PEUX

Présenter à un contrôleur une **trajectoire opposable** : le COSSI suit l'écart à l'échéance, pas l'intention. C'est ce qu'exige l'art. 21(4).

PILOTER LA TRAJECTOIRE

Gouvernance et indicateurs de suivi

Un plan sans indicateur n'est pas une trajectoire, c'est une intention. **Art. 21(2)(f)** impose d'évaluer l'efficacité des mesures.

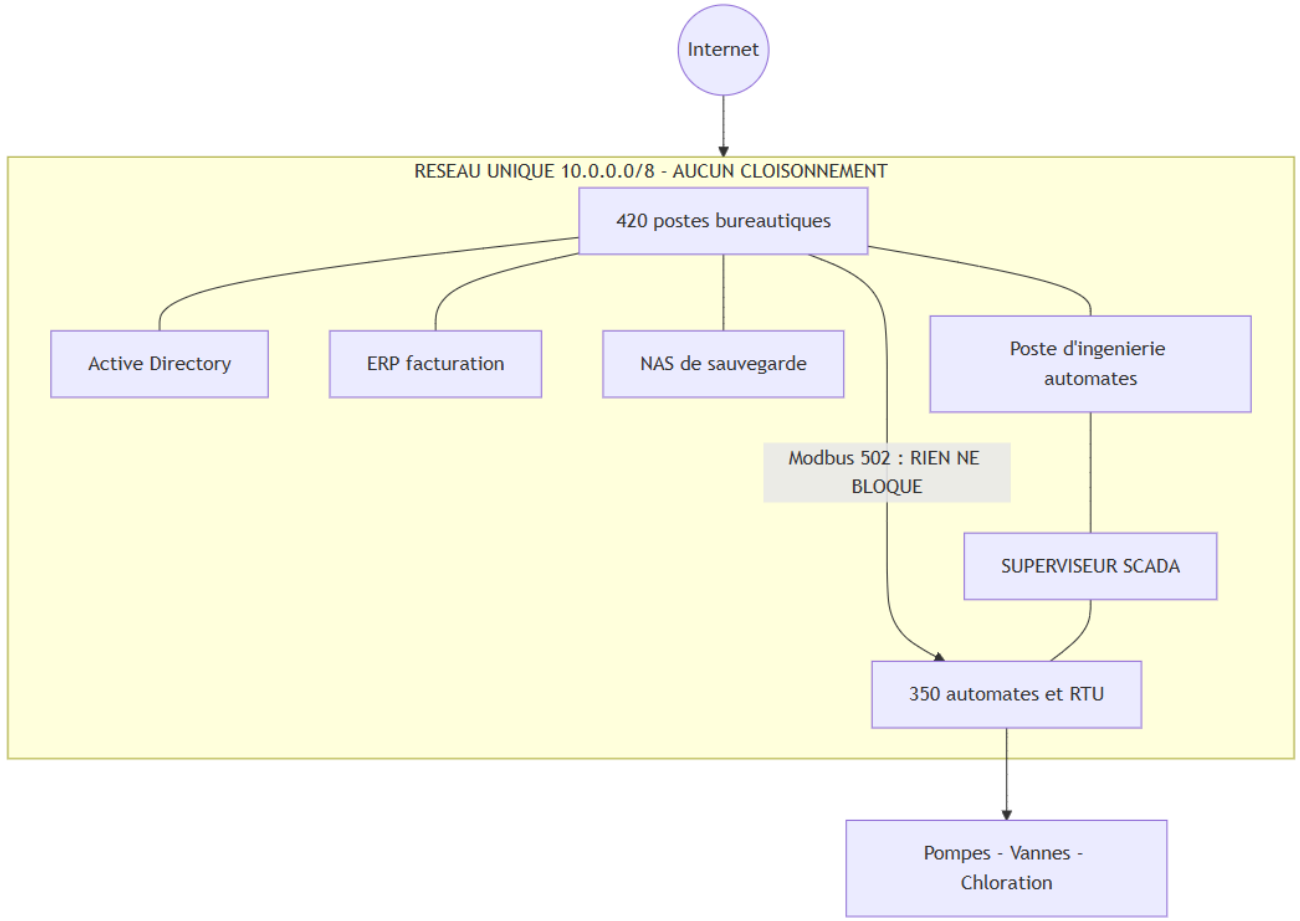
INSTANCE	FRÉQUENCE	RÔLE
COSSI DG, DSI, RSSI, exploitation, DPO	Trimestriel	Approuve, arbitre, suit les indicateurs — **matérialise l'art. 20(1)**
Comité de projet	Mensuel	Suit l'avancement des 39 actions
Point DSI / exploitation	Hebdomadaire	Pendant les phases 0 et 2

INDICATEUR	FIN 2027	FIN 2028
Maturité moyenne art. 21	**2,2 / 4**	**3,3 / 4**
Écarts critiques ouverts	0	0
Actions réalisées à l'échéance	> 80 %	> 90 %
Couverture MFA	95 %	100 %
Tests de restauration réussis	4 / 4	4 / 4
Flux IT → OT hors matrice	**—**	**0**
Dirigeants formés art. 20(2)	100 %	100 %

Le risque assumé du projet lui-même : la résistance de l'exploitation à la segmentation est cotée **élevée**. La parade est de l'associer **dès la matrice de flux** — elle valide les règles, elle ne les subit pas.

L'EXISTANT

Avant : un réseau plat, rien n'arrête la propagation



Un poste bureautique peut ouvrir une session **Modbus/TCP (port 502)** vers n'importe quel automate. Le protocole n'a **ni authentification ni chiffrement** : il ne sait pas qui lui parle.

PREMIÈRE DÉCISION — LE DÉCOUPAGE

Neuf zones, par niveau de criticité

ZONE	NOM	VLAN	RÉSEAU	CRITICITÉ
Z1	Exposition Internet	100	10.100.0.0/24	Moyenne
Z2	IT bureautique	110	10.110.0.0/22	Moyenne
Z3	IT métier	120	10.120.0.0/24	Haute
Z4	Sauvegarde	130	10.130.0.0/24	Critique
▸ **Z5**	**DMZ industrielle** LA CHARNIÈRE	**200**	**10.200.0.0/24**	Critique
Z6	Supervision OT	210	10.210.0.0/24	Vitale
Z7	Contrôle OT	220	10.220.0.0/22	Vitale
Z8	Sites distants	230	10.230.0.0/22	Vitale
Z9	Administration	240	10.240.0.0/24	Critique

CE QUE DIT LE TABLEAU

Une zone regroupe des équipements de **même criticité**, donc de même régime de protection. Le VLAN reprend le 2e octet de l'adresse.

→

CE QUE ÇA DONNE ICI

3 zones vitales (Z6, Z7, Z8) contre 2 seulement de criticité moyenne. La DMZ Z5 est la **seule charnière**.

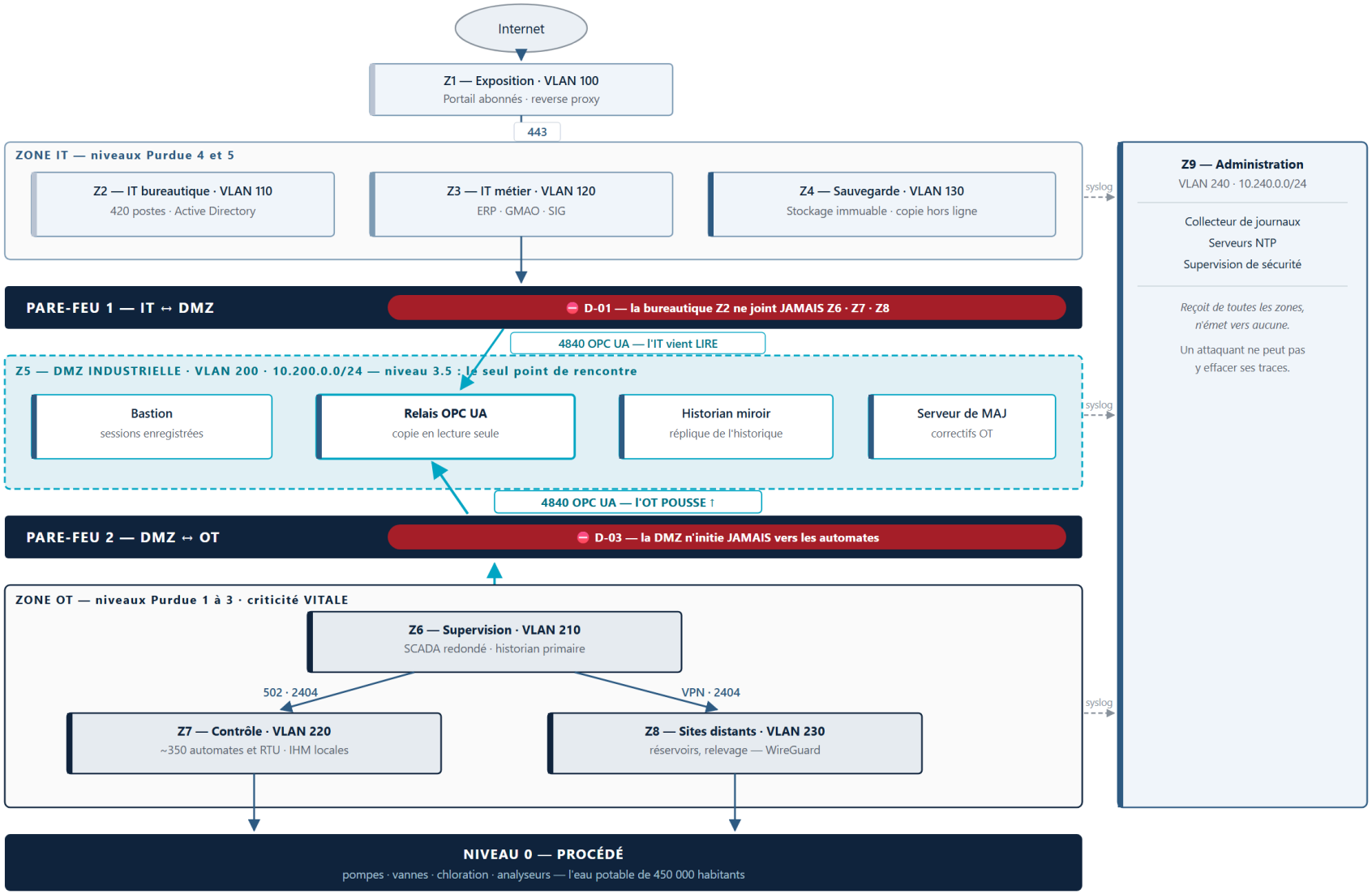
→

DONC JE CHOISIS

Deux pare-feu en cascade, pas un seul. Je ne mets pas la même barrière devant la bureautique et devant les automates qui chlorent l'eau.

HydroRégie — architecture cible segmentée IT / OT

9 zones de criticité homogène · 2 pare-feu en cascade · DMZ industrielle — modèle zones et conduits IEC 62443, adossé à Purdue



LEGENDE

CRITICITE — Vitale · Critique · Haute · Moyenne

Une zone = des equipements de meme criticite, donc de meme regime de protection.
Criticite = impact d'une compromission sur la distribution d'eau potable.

FLUX

- Franchit une frontiere de zone — OPC UA authentifie et chiffre
- Flux interne a une zone — Modbus / IEC 104, jamais route entre zones
- Journalisation vers Z9 — sens unique, jamais de retour
- Interdiction explicite, journalisee et alertee

DEUXIÈME DÉCISION — LES FLUX

La matrice de flux, ligne par ligne

SOURCE	DESTINATION	PORT	JUSTIFICATION
Z6 SCADA	Z5 relais OPC UA	4840	✓ L'OT **pousse** sa donnée, jamais l'inverse
Z3 GMAO	Z5 relais OPC UA	4840	✓ Remontée des compteurs de pompes
Z6 SCADA	Z7 automates	502 · 2404	✓ Pilotage — seul flux vers le procédé
Z9 bastion	Z5 · Z6 · Z7	22 · 3389	✓ Administration tracée, session enregistrée
Toutes zones	Z9 collecteur	6514	✓ Journalisation centralisée
▸ **Z2 bureautique**	**Z5 · Z6 · Z7 · Z8**	**tout**	✗ **LA RÈGLE CENTRALE** CELLE QU'ON TESTE
Z7 automates	Internet	tout	✗ Un automate n'a rien à faire sur Internet
Z5 DMZ	Z7 automates	tout	✗ La DMZ ne doit pas devenir un tremplin
any	any	tout	✗ DENY ALL journalisé — dernière règle

CE QUE DIT LA MATRICE

Tout ce qui n'est pas explicitement autorisé est interdit. Chaque ligne autorisée porte une justification métier et un validateur.

→

CE QUE ÇA DONNE ICI

5 flux autorisés seulement. Le scénario d'attaque de la slide 2 traverse la ligne surlignée — **elle le bloque**.

→

DONC JE PEUX

Faire du test de cette règle **l'indicateur n° 1** de la segmentation : *flux IT → OT hors matrice = 0*. C'est mesurable, donc opposable.

JUSTIFICATION

Pare-feu, VLAN, VPN : des choix argumentés

CHOIX	POURQUOI	CE QU'ON ÉCARTE, ET POURQUOI
2 pare-feu en cascade	Défense en profondeur, jeux de règles et administrateurs séparés	Un seul pare-feu : sa compromission ferait tomber toute la segmentation
VLAN + pare-feu	Le VLAN *organise*, le pare-feu *protège*	Le VLAN seul n'est pas une mesure de sécurité : les VLAN sont routés entre eux
OPC UA aux frontières	Seul protocole industriel authentifié et chiffré	Modbus reste **cantonné à l'intérieur** de l'OT, jamais routé entre zones
VPN WireGuard par site	Une clé par site, `AllowedIPs` en /32 — la maintenance distante passe par le bastion	L'APN privé seul ne chiffre pas et n'empêche pas l'usurpation entre sites
Sonde passive	Elle voit tout et ne peut rien casser	Un IPS en coupure : un faux positif arrêterait la distribution d'eau
Pas de diode en phase 1	La DMZ bien configurée couvre le risque principal	30 à 80 k€ pour un gain marginal — **décision tracée** art. 21(1)

Sur le sens des flux. La règle usuelle « IT → OT par défaut » est ici **inversée** : c'est l'OT qui **pousse** sa donnée vers la DMZ, et l'IT qui vient l'y lire. Aucune session n'est donc jamais initiée depuis l'IT vers l'OT — c'est strictement plus protecteur que la règle de départ.

L'EXIGENCE DIRECTRICE

L'eau doit couler même si tout l'informatique est arrêté

MODE	DÉCLENCHEUR	CE QUI FONCTIONNE ENCORE	TENABLE
Nominal	—	Télégestion complète depuis le SCADA, optimisation énergétique	—
▸ **Dégradé**	SCADA isolé volontairement LE 16 MARS	Les **automates régulent seuls** : niveau, pression, chloration asservie. IHM locales sur site	Plusieurs jours
Manuel	Automate hors service	Manœuvres humaines, dosage vérifié par prélèvements toutes les 4 h	Quelques jours

- Aucun automate ne dépend du SCADA pour **maintenir le service**
- La logique de sûreté (seuils critiques, arrêts de sécurité) est **câblée**, pas seulement logicielle
- Exigence écrite dans les **cahiers des charges des intégrateurs** art. 21(2)(d) et **testée une fois par an** art. 21(2)(f)

La conséquence qui change tout : couper le lien IT ↔ OT devient une décision d'exploitation de **cinq minutes**, pas une catastrophe. C'est cette ligne du tableau qui rend possible la décision de 04 h 30 — deux slides plus loin.

STRUCTURE DE LA RÉPONSE

Cinq phases, de la détection au retour d'expérience

T0 → T+30 MIN
1. Détection
Alarmes SCADA, postes inaccessibles. **Main courante ouverte et horodatée** — c'est elle qui fera foi.

T+30 MIN → T+3 H
2. Qualification
Évaluation d'impact selon la grille. **Confinement** : coupure du lien IT ↔ OT en 33 minutes.

T+3 H → T+24 H
3. Escalade
Cellule de crise réunie physiquement. **Alerte précoce** transmise à T0 + 10 h. Appui CERT-FR.

J+1 → J+10
4. Remédiation
Images disque *avant* réinstallation. Éradication, restauration depuis la copie hors ligne.

J+10 → J+28
5. Clôture et REX
Rapport final, cause profonde, plan d'amélioration. art. 21(2)(f)

- **Deux cellules distinctes** : décision (DG) et technique (DSI/RSSI/exploitation)
- Communication **hors domaine compromis** — annuaire papier
- Une **grille de qualification** écrite décide « important » ou non
- La main courante alimente directement les trois notifications

Le principe qui structure tout : la qualification précède l'escalade, et le confinement ne l'attend pas. On protège d'abord, on qualifie ensuite, on notifie dans les délais.

SCÉNARIO — MARDI 16 MARS 2027

La chronologie horodatée

HEURE	ACTEUR	FAIT ET DÉCISION
▸ 04:12	Astreinte exploitation	**T0** — alarmes SCADA, postes inaccessibles L'HORLOGE ART. 23 DÉMARRE
04:22	Responsable DSI	Chiffrement confirmé sur le serveur de fichiers et l'ERP
▸ 04:30	RSSI	**Décision de couper le lien IT ↔ OT** LA DÉCISION CLÉ
04:45	DSI + exploitation	Lien coupé en **33 minutes** — automates en autonomie, **l'eau continue de couler**
05:00	RSSI	Incident qualifié **important** art. 23(3)
05:30	Cellule de crise	Réunion physique, communication hors domaine
06:15	DSI	Sauvegarde hors ligne intacte → **la rançon ne sera pas payée**
07:00	DSI	Images disque réalisées **avant** toute réinstallation
14:30	Direction générale	**Alerte précoce transmise** — T0 + 10 h 18
15:00	Communication	Information des usagers publiée art. 23(1)

CE QUE DIT LA CHRONOLOGIE

Tout part de **T0 = 04 h 12** : c'est la prise de connaissance, donc le départ des délais de l'art. 23.

→

LA SITUATION À 04 H 30

Chiffrement confirmé côté IT. L'OT n'est **pas encore** touché, mais rien ne l'en empêche : le réseau est plat.

→

DONC JE DÉCIDE

De **couper le lien IT ↔ OT**. Je peux le faire parce que le mode dégradé du tableau précédent est testé : ça coûte 33 minutes, **pas le service d'eau**.

ARTICLE 23 — LES LIVRABLES RÉDIGÉS

Trois délais, trois documents écrits

24 HEURES · art. 23(4)(a)

Alerte précoce

Dire qu'un incident existe — **pas** l'avoir compris. Soupçon d'acte illicite, effet transfrontière.

`annexes/A-alerte-precoce-24h.md`

✓ **T0 + 10 h 18**

72 HEURES · art. 23(4)(b)

Notification d'incident

Évaluation initiale, gravité, impact, **indicateurs de compromission**. Met à jour l'alerte.

`annexes/B-notification-72h.md`

✓ **T0 + 60 h 48**

1 MOIS · art. 23(4)(d)

Rapport final

Description détaillée, **cause profonde**, mesures appliquées, impact transfrontière éventuel.

`annexes/C-rapport-final-1-mois.md`

✓ **J + 28**

ÉCHÉANCE	DÉLAI	ARTICLE	RÉALISÉ
Alerte précoce	24 h après connaissance	23(4)(a)	✓ T0 + 10 h 18 — **13 h 42 de marge**
Notification d'incident	72 h après connaissance	23(4)(b)	✓ T0 + 60 h 48 — **11 h 12 de marge**
▸ Rapport final	1 mois après **la notification** LE PIÈGE	23(4)(d)	✓ J + 28 — 5 jours de marge
Information des usagers	sans retard injustifié	23(1)	✓ J0 à 15 h 00
Notification CNIL	72 h — **horloge distincte**	art. 33 RGPD	✓ J + 2
Réponse de l'autorité	24 h après l'alerte précoce	23(5)	Reçue — orientations et appui

CE QUE DIT LE TABLEAU

Trois échéances NIS2, plus **deux horloges parallèles** : les usagers et la CNIL.

→

LE PIÈGE DE LA LIGNE 3

Le mois court depuis **la notification des 72 h**, pas depuis la découverte. Compter depuis T0 ferait perdre 3 jours.

→

DONC JE CONCLUS

Les trois délais sont tenus, avec marge. Et notifier tôt rapporte : l'art. 23(5) oblige l'autorité à répondre sous 24 h.

CE QUE CE CAS DÉMONTRE

Trois messages à retenir

1 Les mesures les moins chères sont celles qui sauvent

Six des sept facteurs décisifs pendant la crise venaient de la phase 0 — **95 k€ sur 956 k€**.

2 La segmentation ne se justifie pas par la conformité

Elle se justifie par les **six jours de télégestion perdus** faute de l'avoir faite.

3 En OT, la bonne question n'est pas « comment empêcher l'attaque »

C'est **« comment continuer à distribuer de l'eau pendant l'attaque »**.

> La conformité NIS2 est **une trajectoire documentée**, pas une case à cocher. Devant un contrôle, un plan daté avec ses preuves vaut mieux qu'un discours de conformité totale.

GRILLE D'ÉVALUATION

Où trouver quoi dans le dossier

LIVRABLE	CONFORMITÉ RÉGLEMENTAIRE	CLARTÉ ET STRUCTURATION	ARGUMENTATION TECHNIQUE
Note de qualification `job-1-qualification.md`	Statut essentiel établi par 3 voies · obligations art. 20, 21, 23 · autorité ANSSI · enregistrement art. 3(4)	Raisonnement en 4 questions — **slides 3 à 5**	Secteur annexe I pt 6 · calcul de taille détaillé, hypothèse de consolidation signalée
Analyse d'écart `job-2-analyse-ecart.md`	**10 familles** de l'art. 21 cotées · 18 écarts qualifiés absent / partiel	Matrice impact/effort · 4 phases · 39 actions — **slides 6 à 10**	Chaque écart relié à une action, un coût, une échéance et un propriétaire
Schéma IT/OT `schemas/architecture-cible.svg`	Segmentation réelle · 9 zones · DMZ industrielle	**Légende et 4 niveaux de criticité — slides 11 à 16**	Pare-feu, VLAN, VPN justifiés, **avec les options écartées**
Crise et notifications `job-4-crise-notifications.md`	24 h / 72 h / 1 mois respectés · art. 23(1) et RGPD traités	Chronologie horodatée en 5 phases — **slides 17 à 19**	Les **3 notifications rédigées**, cohérentes avec la chronologie

Le dossier se lit sans oral. Un document par bloc, ses annexes rédigées, les schémas sources et les scripts de vérification — chaque affirmation réglementaire renvoie à son article, chaque choix technique à sa justification et aux options écartées.